

Drafting a Network Security Policy (3e)

Network Security, Firewalls, and VPNs, Third Edition - Supplemental Lab 05

Student:

Christopher Phan

Email:

cphan@udallas.edu

Time on Task:

Progress:

100%

Report Generated: Thursday, June 23, 2022 at 1:29 PM

Guided Exercises

Part 1: Research Critical Security Controls and Policy Statements

5. **Summarize** the guidelines for the *Wireless Access Control* section.

There are ten controls for Wireless Access Control: (1) maintaining an inventory of authorized wireless access points, (2) detecting wireless access points connected to the wireless network, (3) using a wireless intrusion detection system, (4) disabling wireless access on devices if not required, (5) limiting wireless access on client devices, (6) disabling peer-to-peer wireless network capabilities on wireless clients, (7) leveraging the advanced encryption standard to encrypt wireless data, (8) using wireless authentication protocols that require mutual, multi-factor authentication, (9) disabling wireless peripheral access to devices, and (10) creating separate wireless network for personal and untrusted devices. How the first control is implemented is through maintaining the inventory of a firm's authorized wireless access points which are connected to their wired network. The second control is implemented through configuring the network to have tools that scan any vulnerabilities and alert that there is unauthorized wireless access points that are being connected to the wired network. For the third control, it can be implemented through IDS systems that detect and alert unauthorized wireless access points are being connected to the network. For the fourth control, it can be implemented through disabling any wireless devices that have no purpose towards the business. For the fifth control, it can be implemented through configuring client machines that have wireless access to be only connected to authorized wireless networks and are restricted to what is business necessary. For the sixth control, it can be implemented through disabling peer-to-peer wireless network functions on wireless clients. For the seventh control, it can be implemented through using AES, creating encrypted traffic for all data. For the eighth control, it can be implemented through authentication protocols requiring multi-factor authentication for wireless networks. For the ninth control, it can be implemented through ensuring that all access is required for the business in monitoring all wireless peripheral devices. Lastly for the tenth control, it can be implemented in creating a separate wireless network that is specifically for personal or untrusted devices, filtering and auditing this network regularly.

12. **Describe** the various components that make up a typical IT security policy.

I chose three policies from the SANS Security Policy Templates: Acceptable Encryption Policy, End User Encryption Key Protection Policy, and Password Protection Policy. For the Acceptable Encryption Policy, what it entails is algorithm requirements, hash function requirements, key agreement and authentication, and lastly key generation. For the End User Encryption Protection Policy, that entails requirements of secret key encryption keys, public key encryption keys, public key infrastructure keys, other public key encryption keys, commercial or outside organization public key infrastructure keys, PGP key pairs, hardware token storage, PIN, passwords, and passphrases, and loss and theft policies about any possible unauthorized disclosures. Lastly, for password protection policy, it requires guidelines for password creation, password changes, password protection, application development, and multi-factor authentication. As can be shown in the three policies, data security is of the highest priority and each policies describes a specific point of that data security. For the acceptable encryption, it provides a baseline for the randomization of keys in how no one key is ever the same once given nor repeatedly, creating tighter security that malicious actors can not exploit. For end user encryption key protection builds upon this as well, in the necessity of multiple keys with various functions, allowing for multiple necessary requirements to enter into a network, such as necessary certificates, smart cards, computer generation, encryption, passwords, hardware tokens for employees, clients, and outside organizations. This protects all access points that are connected to a business, as well as details in any case any of those pieces are compromised in any way. Lastly for the password protection, it details how passwords need to be based on set guidelines on least privilege, on how the password must be created, how the password must be changed whenever there is a suspected compromise, how the passwords must be confidential and protected with the proper physical and technological barriers, and that there must be multiple factors into getting authorized that are not based on a simple one-way entry. What these policies show a emphasis on redundancy, which is the key factors in data security of any kind, how these systems stack onto each other.

Part 2: Draft Policy Requirements and Create a Wireless Standard

1. **Write** a sample requirement statement that would be a part of each of the following policies.

- User Authentication Policy: This outlines the need for all users to be authenticated against a central database.
- Authorized Networked Devices Policy: This outlines what device types/models are allowed.
- Email Acceptable Use Policy: This outlines what confidential, personally identifiable data is allowed.

Policies should be written with clear, simple, testable language. The more ambiguous the language used, the more difficult it is to enforce compliance. Remember, this is a practice exercise and there is no absolute wrong or right way to word a policy statement.

User Authentication Policy - Requirement 1: All employees who are signing into the system must have a username and password assigned to their account. For password requirements, look at the Password Protection Policy. As well as this requirement, they must have a PIN number system that is assigned to them through RSA, making them put in a randomized 6 digit code every time they sign in. Lastly, whenever entering the system through their devices, must use their fingerprints too to be fully authenticated. With all three factors, they complete a multi-factor authentication. - Requirement 2: For clients, they must go through a username and password requirement, but have no requirement for a PIN. - Requirement 3: For any workers that have to come into the building must be assigned a smart card to enter and fingerprint scan. Authorized Networked Devices Policy - Requirement 1: All devices must be approved beforehand by the administrator and cannot be personal devices unless directly stated otherwise. - Requirement 2: All devices are set to be only connected to the departments necessary for it and cannot be an access point for any other departments. - Requirement 3: Security protocols are set up onto all devices, such as anti-malware software, all software is up-to-date on device, host-based firewall is placed onto the device, authentication services are installed, all communications and services are encrypted and salted, and automated services such as automatic log-off processes. - Requirement 4: If in the case of loss or theft, that it be immediately reported to InfoSec teams in case of any uncompromised data. User will be immediately instructed in what to do to mitigate any risk by the InfoSec team. Email Acceptable Use Policy - Requirement 1: All emails must be conducted in a professional manner and only used for conducting business, and not for any personal use whatsoever. - Requirement 2: Employees must go through mandatory training about any malicious attacks that may appear through emails, such as phishing. - Requirement 3: All emails are subject to be monitored with no expectation of privacy. - Requirement 4: No other third-party email services can be used, nor can they be stored for personal use. All emails must be conducted through approved channels by the company.

8. **Paste** the updated Wireless Communication Standard here.

Last Update Status: Updated June 2022

1. Overview See Purpose.

2. Purpose This standard specifies the technical requirements that wireless infrastructure devices must satisfy to connect to a Little Jerry's Beverage Company network. Only those wireless infrastructure devices that meet the requirements specified in this standard or are granted an exception by the InfoSec Team are approved for connectivity to a Little Jerry's Beverage Company network. Network devices including, but not limited to, hubs, routers, switches, firewalls, remote access devices, modems, or wireless access points, must be installed, supported, and maintained by an Information Security (Infosec) approved support organization. Lab network devices must comply with the Lab Security Policy.

3. Scope All employees, contractors, consultants, temporary and other workers at Little Jerry's Beverage Company and its subsidiaries, including all personnel that maintain a wireless infrastructure device on behalf of Little Jerry's Beverage Company, must comply with this standard. This standard applies to wireless devices that make a connection the network and all wireless infrastructure devices that provide wireless connectivity to the network. Infosec must approve exceptions to this standard in advance.

4. Standard

4.1 General Requirements All wireless infrastructure devices that connect to a Little Jerry's Beverage Company network or provide access to Little Jerry's Beverage Company Confidential, Little Jerry's Beverage Company Highly Confidential, or Little Jerry's Beverage Company Restricted information must:

- Be able to have an accurate authorized inventory of all access points that are connected to the wire network.
- No wireless access devices can be connected to the network if they have no business purpose.
- No wireless peripheral access of devices, such as Bluetooth, can be connected to the network unless they have approved and authorized access to the network for business purposes.

4.2 Protection and Monitoring of the Network

- The network must have scanning tools to detect and alert any unauthorized wireless access points that are connected to the wired network.
- There must be as well a wireless intrusion detection system to detect and alert any unauthorized wireless access points connected to the network.
- Installment of an Advanced Encryption Standard, so all data is encrypted within transit.
- There must be a separate wireless network for all devices that are personal or untrusted, such as unauthorized laptops, mobile devices. This network will be treated as untrusted and always filtered and will be audited regularly.
- The network will authentication protocols, such as Extensible Authentication Protocol-Transport Layer Security, which will require mutual MFA.

4.3 Configuration of the Network

- Along with the configuration where the network will be scanned for any malicious activity, there will be a configuration specifically for client machines, where they will only have access to an authorized wireless network only for business purposes. This wireless network will be restricted from all other wireless networks.
- There will be no peer-to-peer wireless network capabilities that are functional on wireless clients.

5. Policy Compliance

5.1 Compliance Measurement The Infosec team will verify compliance to this policy through various methods, including but not limited to, periodic walk-thrus, video monitoring, business tool reports, internal and external audits, and feedback to the policy owner.

5.2 Exceptions Any exception to the policy must be approved by the Infosec Team in advance.

5.3 Non-Compliance An employee found to have violated this policy may be subject to disciplinary action, up to and including termination of employment.

6 Related Standards, Policies and Processes

- Lab Security Policy

7 Revision History

Date of Change	Responsible	Summary of Change
June 2014	SANS Policy Team	Updated and converted to new format.
June 2022	Christopher Phan	Updated standard requirements for policy.

Challenge Exercises

Part 1: Conduct Additional Research

Conduct additional research about the Critical Security Controls. What is another name commonly associated with this same set of controls?

Center for Internet Security

Part 2: Draft a Wireless Communication Policy

Drafting a Network Security Policy (3e)

Network Security, Firewalls, and VPNs, Third Edition - Supplemental Lab 05

Download the Wireless Communication Policy template from <http://www.sans.org/security-resources/policies/>. **Customize** the policy components for Little Jerry's Beverage Corporation, then **paste** your completed policy here.

Last Update Status: Updated June 2022

1. Overview See Purpose.

2. Purpose This standard specifies the technical requirements that wireless infrastructure devices must satisfy to connect to a Little Jerry's Beverage Company network. Only those wireless infrastructure devices that meet the requirements specified in this standard or are granted an exception by the InfoSec Team are approved for connectivity to a Little Jerry's Beverage Company network. Network devices including, but not limited to, hubs, routers, switches, firewalls, remote access devices, modems, or wireless access points, must be installed, supported, and maintained by an Information Security (Infosec) approved support organization. Lab network devices must comply with the Lab Security Policy.

3. Scope All employees, contractors, consultants, temporary and other workers at Little Jerry's Beverage Company and its subsidiaries, including all personnel that maintain a wireless infrastructure device on behalf of Little Jerry's Beverage Company, must comply with this standard. This standard applies to wireless devices that make a connection the network and all wireless infrastructure devices that provide wireless connectivity to the network. Infosec must approve exceptions to this standard in advance.

4. Standard

4.1 General Requirements All wireless infrastructure devices that connect to a Little Jerry's Beverage Company network or provide access to Little Jerry's Beverage Company Confidential, Little Jerry's Beverage Company Highly Confidential, or Little Jerry's Beverage Company Restricted information must:

- Be able to have an accurate authorized inventory of all access points that are connected to the wire network.
- No wireless access devices can be connected to the network if they have no business purpose.
- No wireless peripheral access of devices, such as Bluetooth, can be connected to the network unless they have approved and authorized access to the network for business purposes.

4.2 Protection and Monitoring of the Network

- The network must have scanning tools to detect and alert any unauthorized wireless access points that are connected to the wired network.
- There must be as well a wireless intrusion detection system to detect and alert any unauthorized wireless access points connected to the network.
- Installment of an Advanced Encryption Standard, so all data is encrypted within transit.
- There must be a separate wireless network for all devices that are personal or untrusted, such as unauthorized laptops, mobile devices. This network will be treated as untrusted and always filtered and will be audited regularly.
- The network will authentication protocols, such as Extensible Authentication Protocol-Transport Layer Security, which will require mutual MFA.

4.3 Configuration of the Network

- Along with the configuration where the network will be scanned for any malicious activity, there will be a configuration specifically for client machines, where they will only have access to an authorized wireless network only for business purposes. This wireless network will be restricted from all other wireless networks.
- There will be no peer-to-peer wireless network capabilities that are functional on wireless clients.

5. Policy Compliance

5.1 Compliance Measurement The Infosec team will verify compliance to this policy through various methods, including but not limited to, periodic walk-thrus, video monitoring, business tool reports, internal and external audits, and feedback to the policy owner.

5.2 Exceptions Any exception to the policy must be approved by the Infosec Team in advance.

5.3 Non-Compliance An employee found to have violated this policy may be subject to disciplinary action, up to and including termination of employment.

6 Related Standards, Policies and Processes

- Lab Security Policy

7 Revision History

Date of Change	Responsible	Summary of Change
June 2014	SANS Policy Team	Updated and converted to new format.
June 2022	Christopher Phan	Updated standard requirements for policy.